# IBM BOB ENTERPRISE: SECURITY, PRIVACY & ARCHITECTURE WHITEPAPER

Enterprise-Grade Defense-in-Depth for AI Document Intelligence & Box Integration

| | |
|---|---|
| **Document Version** | Version 3.4 (Enterprise Edition) |
| **Target Audience** | Chief Information Security Officers (CISOs), Security Architects, Compliance Officers |
| **Authoring Group** | IBM Cybersecurity & AI Governance Directorate |
| **Classification** | Public Whitepaper / Approved for Customer Due Diligence |

## 1. Core Security Architecture Principles

IBM Bob is engineered on a foundation of **zero trust**, **zero model training on customer data**, and **evidence-first deterministic execution**. Unlike consumer AI systems that ingest and retain user prompts to update public weights, IBM Bob enforces absolute data isolation.

> **Mandatory Policy:** Under no circumstances are customer documents, prompts, or generated responses retained to train, fine-tune, or improve foundation models. Ingestion is 100% ephemeral and in-memory.

## 2. Model Context Protocol (MCP) Security Model

The Box MCP connector establishes a cryptographically secure, least-privilege boundary between the Bob execution engine and Box Content Cloud:

- **Ephemeral Token Scoping:** Bob queries Box using short-lived OAuth 2.0 access tokens scoped strictly to the requesting user's permission context.
- **In-Memory Context Window:** Document pages retrieved for reasoning exist only during execution and are immediately zeroized in memory upon completion.
- **Box Shield Integration:** Bob respects Box Shield classification labels (e.g., Restricted, Confidential, PII) and enforces downstream DLP policies.
- **Deterministic Provenance:** Every statement generated contains a verifiable hash linking back to the originating Box file ID and chunk coordinate.

## 3. Threat Modeling & Continuous Testing

IBM conducts continuous red-team exercises, weekly dynamic vulnerability assessments, and independent third-party penetration tests. All code undergoes automated SAST, dependency vulnerability scanning (Mend/Snyk), and container image verification against Red Hat UBI minimal baselines.